安全與合規

Security & Compliance

AWS Certified DevOps Engineer – Professional (DOP-C02) ｜ 官方考試權重 17%

第 1 題 （題庫 No.3 · 單選）

A company uses AWS Organizations, AWS Control Tower, AWS Config, and Terraform to manage its AWS accounts and resources. The company must ensure that users deploy only AWS Lambda functions that are connected to a VPC in member AWS accounts. Which solution will meet these requirements with the LEAST operational effort?

A. Configure AWS Control Tower to use proactive controls (guardrails). Enable optional controls implemented with AWS CloudFormation hooks for Lambda on all OUs.

B. Create a new SCP that checks the lambda:VpcIds condition key for allowed values.

C. Create a custom AWS Config rule to detect non-VPC-connected Lambda functions.

D. Create a new SCP with a conditional statement that denies Lambda creation if lambda:VpcIds is null.

我的答案：_____

第 2 題 （題庫 No.13 · 複選（Select 3））

A company is using an organization in AWS Organizations to manage multiple AWS accounts. The company ' s development team wants to use AWS Lambda functions to meet resiliency requirements and is rewriting all applications to work with Lambda functions that are deployed in a VPC. The development team is using Amazon Elastic Pile System (Amazon EFS) as shared storage in Account A in the organization. The company wants to continue to use Amazon EPS with Lambda Company policy requires all serverless projects to be deployed in Account B. A DevOps engineer needs to reconfigure an existing EFS file system to allow Lambda functions to access the data through an existing EPS access point. Which combination of steps should the DevOps engineer take to meet these requirements? (Select THREE.)

A. Update the EFS file system policy to provide Account B with access to mount and write to the EFS file system in Account A.

B. Create SCPs to set permission guardrails with fine-grained control for Amazon EFS.

C. Create a new EFS file system in Account B Use AWS Database Migration Service (AWS DMS) to keep data from Account A and Account B synchronized.

D. Update the Lambda execution roles with permission to access the VPC and the EFS file system.

E. Create a VPC peering connection to connect Account A to Account B.

F. Configure the Lambda functions in Account B to assume an existing IAM role in Account A.

我的答案：_____

第 3 題 （題庫 No.86 · 單選）

A company manages a multi-tenant environment in its VPC and has configured Amazon GuardDuty for the corresponding AWS account. The company sends all GuardDuty findings to AWS Security Hub. Traffic from suspicious sources is generating a large number of findings. A DevOps engineer needs to implement a solution to automatically deny traffic across the entire VPC when GuardDuty discovers a new suspicious source. Which solution will meet these requirements?

A. Create a GuardDuty threat list. Configure GuardDuty to reference the list. Create an AWS Lambda function that will update the threat list Configure the Lambda function to run in response to new Security Hub findings that come from GuardDuty.

B. Configure an AWS WAF web ACL that includes a custom rule group. Create an AWS Lambda function that will create a block rule in the custom rule group Configure the Lambda function to run in response to new Security Hub findings that come from GuardDuty

C. Configure a firewall in AWS Network Firewall. Create an AWS Lambda function that will create a Drop action rule in the firewall policy Configure the Lambda function to run in response to new Security Hub findings that come from GuardDuty

D. Create an AWS Lambda function that will create a GuardDuty suppression rule. Configure the Lambda function to run in response to new Security Hub findings that come from GuardDuty.

我的答案：_____

第 4 題 （題庫 No.144 · 單選）

A company manages environments for its application in multiple AWS accounts. Each environment account is in a different OU in AWS Organizations. A DevOps team is responsible for the application deployment process across the environments. The deployment process uses an AWS CodePipeline pipeline in a Shared Services account. The DevOps team members are in the same user group. The team members have administrative access to all accounts through AWS IAM Identity Center. A recent deployment problem in the development environment required the DevOps team to perform manual steps. The deployment to the production environment then resulted in an incident that caused the pipeline to fail, blocking new deployments for several hours. A DevOps engineer needs to ensure that only the pipeline can perform deployments in the production environment. The DevOps engineer must have access to the environment in case of an emergency. Which solution will meet these requirements with the MOST operational efficiency?

A. Update the DevOps group to have the ReadOnlyAccess permission set for the production accounts. Configure the DevOps engineer user with a new permission set that has AdministratorAccess permissions and that allows the user to assume the pipeline role. Add an SCP that denies modification of resources by any entity other than the pipeline role.

B. Create an SCP that denies all write actions for the DevOps team members on the production OU. Configure a new user in IAM Identity Center for the DevOps engineer with a new permission set that has AdministratorAccess permissions. Add an SCP that denies modification of resources by any entity other than the pipeline role.

C. Update the DevOps group to be able to assume the pipeline role for the production accounts. Configure a new user in IAM Identity Center for the DevOps engineer with a new permission set that has AdministratorAccess permissions. Add an SCP that denies modification of resources by any entity other than the DevOps engineer.

D. Create an SCP that denies all write actions for the DevOps team members on the production OU. Use a specific tag to tag the resources that CodePipeline provisions. Add an SCP that denies modification of tagged resources by any entity other than the DevOps engineer.

我的答案：_____

第 5 題 （題庫 No.204 · 複選（Select 2））

A company uses AWS Organizations to manage its AWS accounts. A DevOps engineer must ensure that all users who access the AWS Management Console are authenticated through the company ' s corporate identity provider (IdP). Which combination of steps will meet these requirements? (Select TWO.)

A. Use Amazon GuardDuty with a delegated administrator account. Use GuardDuty to enforce denial of 1AM user logins

B. Use AWS 1AM Identity Center to configure identity federation with SAML 2.0.

C. Create a permissions boundary in AWS 1AM Identity Center to deny password logins for 1AM users.

D. Create 1AM groups in the Organizations management account to apply consistent permissions for all 1AM users.

E. Create an SCP in Organizations to deny password creation for 1AM users.

我的答案：_____

第 6 題 （題庫 No.220 · 單選）

A company is launching an application. The application must use only approved AWS services. The account that runs the application was created less than 1 year ago and is assigned to an AWS Organizations OU. The company needs to create a new Organizations account structure. The account structure must have an appropriate SCP that supports the use of only services that are currently active in the AWS account. The company will use AWS Identity and Access Management (IAM) Access Analyzer in the solution. Which solution will meet these requirements?

A. Create an SCP that allows the services that IAM Access Analyzer identifies. Create an OU for the account. Move the account into the new OU. Attach the new SCP to the new OU. Detach the default FullAWSAccess SCP from the new OU.

B. Create an SCP that denies the services that IAM Access Analyzer identifies. Create an OU for the account. Move the account into the new OIJ. Attach the new SCP to the new OU.

C. Create an SCP that allows the services that IAM Access Analyzer identifies. Attach the new SCP to the organization ' s root.

D. Create an SCP that allows the services that IAM Access Analyzer identifies. Create an OU for the account. Move the account into the new OU. Attach the new SCP to the management account. Detach the default FullAWSAccess SCP from the new OU.

我的答案：_____

第 7 題 （題庫 No.266 · 單選）

A company uses an organization in AWS Organizations to manage multiple AWS accounts. The company ' s internal auditors have administrative access to a single audit account within the organization. A DevOps engineer needs to provide a solution to give the auditors read-only access to all accounts within the organization, including new accounts created in the future. Which solution will meet these requirements?

A. Enable AWS IAM Identity Center for the organization. Create a read-only access permission set. Create a permission group that includes the auditors. Grant access to every account in the organization to the auditor permission group by using the read-only access permission set.

B. Create an AWS CloudFormation stack set to deploy an IAM role that trusts the audit account and allows read-only access. Enable automatic deployment for the stack set. Set the organization root as a deployment target.

C. Create an SCP that provides read-only access for users in the audit account. Apply the policy to the organization root.

D. Enable AWS Config in the organization management account. Create an AWS managed rule to check for a role in each account that trusts the audit account and allows read-only access. Enable automated remediation to create the role if it does not exist.

我的答案：_____

第 8 題 （題庫 No.343 · 單選）

A company has an organization in AWS Organizations. A DevOps engineer needs to maintain multiple AWS accounts that belong to different OUs in the organization. All resources, including 1AM policies and Amazon S3 policies within an account, are deployed through AWS CloudFormation. All templates and code are maintained in an AWS CodeCommit repository Recently, some developers have not been able to access an S3 bucket from some accounts in the organization. The following policy is attached to the S3 bucket. What should the DevOps engineer do to resolve this access issue?

A. Modify the S3 bucket policy Turn off the S3 Block Public Access setting on the S3 bucket In the S3 policy, add the awsSourceAccount condition. Add the AWS account IDs of all developers who are experiencing the issue.

B. Verify that no 1AM permissions boundaries are denying developers access to the S3 bucket Make the necessary changes to IAM permissions boundaries. Use an AWS Config recorder in the individual developer accounts that are experiencing the issue to revert any changes that are blocking access. Commit the fix back into the CodeCommit repository. Invoke deployment through Cloud Formation to apply the changes.

C. Configure an SCP that stops anyone from modifying 1AM resources in developer OUs. In the S3 policy, add the awsSourceAccount condition. Add the AWS account IDs of all developers who are experiencing the issue Commit the fix back into the CodeCommit repository Invoke deployment through CloudFormation to apply the changes

D. Ensure that no SCP is blocking access for developers to the S3 bucket Ensure that no 1AM policy permissions boundaries are denying access to developer 1AM users Make the necessary changes to the SCP and 1AM policy permissions boundaries in the CodeCommit repository Invoke deployment through CloudFormation to apply the changes

我的答案：_____

第 9 題 （題庫 No.355 · 複選（Select 3））

A DevOps engineer is building the infrastructure for an application. The application needs to run on an Amazon Elastic Kubernetes Service (Amazon EKS) cluster that includes Amazon EC2 instances. The EC2 instances need to use an Amazon Elastic File System (Amazon EFS) file system as a storage backend. The Amazon EFS Container Storage Interface (CSI) driver is installed on the EKS cluster. When the DevOps engineer starts the application, the EC2 instances do not mount the EFS file system. Which solutions will fix the problem? (Select THREE.)

A. Switch the EKS nodes from Amazon EC2 to AWS Fargate.

B. Add an inbound rule to the EFS file system ' s security group to allow NFS traffic from the EKS cluster.

C. Create an IAM role that allows the Amazon EFS CSI driver to interact with the file system.

D. Set up AWS DataSync to configure file transfer between the EFS file system and the EKS nodes.

E. Create a mount target for the EFS file system in the subnet of the EKS nodes.

F. Disable encryption on the EFS file system.

我的答案：_____

第 10 題 （題庫 No.409 · 單選）

A company uses an Amazon Elastic Kubernetes Service (Amazon EKS) cluster to deploy its web applications on containers. The web applications contain confidential data that cannot be decrypted without specific credentials. A DevOps engineer has stored the credentials in AWS Secrets Manager. The secrets are encrypted by an AWS Key Management Service (AWS KMS) customer managed key. A Kubernetes service account for a third-party tool makes the secrets available to the applications. The service account assumes an IAM role that the company created to access the secrets. The service account receives an Access Denied (403 Forbidden) error while trying to retrieve the secrets from Secrets Manager. What is the root cause of this issue?

A. The IAM role that is attached to the EKS cluster does not have access to retrieve the secrets from Secrets Manager.

B. The key policy for the customer managed key does not allow the Kubernetes service account IAM role to use the key.

C. The key policy for the customer managed key does not allow the EKS cluster IAM role to use the key.

D. The IAM role that is assumed by the Kubernetes service account does not have permission to access the EKS cluster.

我的答案：_____

解答與解析　Answer Key

解析取自題庫原文，未經 AWS 官方審核；若與官方文件有出入，以官方文件為準。

第 1 題（No.3）　正確答案：D

Use a Service Control Policy (SCP) with a Null condition on lambda:VpcIds to deny Lambda function creation or update when not VPC-attached. This enforces compliance across all accounts automatically without manual remediation, aligning with AWS Control Tower governance recommendations.

涉及服務：CloudFormation、Terraform、Lambda、Config、Organizations/Control Tower、IAM/SCP

第 2 題（No.13）　正確答案：A、E、F

A Lambda function in one account can mount a file system in a different account. For this scenario, you configure VPC peering between the function VPC and the file system VPC.
https://docs.aws.amazon.com
/lambda/latest/dg/services-efs.html
https://aws.amazon.com/ru/blogs/storage/mount-amazon-efs-file-systems-cross-account-from-amazon-eks/
1. Need to update the file system policy on EFS to allow mounting the file system into Account B.
File System Policy
$ cat file-system-policy.json
{
" Statement " : [
{
" Effect " : " Allow " ,
" Action " : [
" elasticfilesystem:ClientMount " ,
" elasticfilesystem:ClientWrite "
],
" Principal " : {
" AWS " : " arn:aws:iam:: < aws-account-id-A > :root " # Replace with AWS account ID of EKS cluster
}
}
]
}
2. Need VPC peering between Account A and Account B as the pre-requisite
3. Need to assume cross-account IAM role to describe the mounts so that a specific mount can be chosen.

涉及服務：Lambda、EKS、Organizations/Control Tower、IAM/SCP、VPC

第 3 題（No.86）　正確答案：C

https://aws.amazon.com/blogs/security/automatically-block-suspicious-traffic-with-aws-network-firewall-and-amazon-guardduty/

涉及服務：Lambda、VPC、GuardDuty、Security Hub、WAF/Shield

第 4 題（No.144）　正確答案：A

The requirement is to restrict production deployments strictly to the pipeline, while still allowing emergency access to a specific engineer.
* The best approach is to restrict the DevOps team to read-only access in production accounts, minimizing risk of manual changes (Option A).

* The DevOps engineer can have an admin permission set but assume the pipeline IAM role for deployment, enforcing strict control.
* Applying an SCP to deny modification by anyone other than the pipeline role enforces this at the organization level. Option B is similar but unnecessarily creates separate IAM users, increasing management overhead. Option C grants the DevOps engineer broader permissions that may conflict with controls. Option D complicates management with tagging and SCPs, increasing operational overhead.
Reference:
AWS Organizations Service Control Policies (SCPs): " SCPs can restrict what actions identities in member accounts can perform, even for administrators. " (AWS Organizations SCP Documentation)
IAM Identity Center Role Assumption Best Practices: " Use role assumption for limited elevated permissions instead of broad admin access. " (AWS IAM Best Practices)
涉及服務：CodePipeline、Organizations/Control Tower、IAM/SCP

第 5 題（No.204） 正確答案：B、E

Step 1: Using AWS IAM Identity Center for SAML-based Identity Federation To ensure that all users accessing the AWS Management Console are authenticated via the corporate identity provider (IdP), the best approach is to set up identity federation with AWS IAM Identity Center (formerly AWS SSO) using SAML 2.0.
Action: Use AWS IAM Identity Center to configure identity federation with the corporate IdP that supports SAML 2.0.
Why: SAML 2.0 integration enables single sign-on (SSO) for users, allowing them to authenticate through the corporate IdP and gain access to AWS resources.
Reference: AWS documentation on IAM Identity Center and SAML Federation.
This corresponds to Option B: Use AWS IAM Identity Center to configure identity federation with SAML 2.0.
Step 2: Creating an SCP to Deny Password Logins for IAM UsersTo enforce that IAM users do not create passwords or access the Management Console directly without going through the corporate IdP, you can create a Service Control Policy (SCP) in AWS Organizations that denies password creation for IAM users.
Action: Create an SCP that denies password creation for IAM users.
Why: This ensures that users cannot set passwords for their IAM user accounts, forcing them to use federated access through the corporate IdP for console login.
Reference: AWS documentation on Service Control Policies.
This corresponds to Option E: Create an SCP in Organizations to deny password creation for IAM users.
涉及服務：Organizations/Control Tower、IAM/SCP、GuardDuty

第 6 題（No.220） 正確答案：A

To meet the requirements of creating a new Organizations account structure with an appropriate SCP that supports the use of only services that are currently active in the AWS account, the company should use the following solution:
Create an SCP that allows the services that IAM Access Analyzer identifies. IAM Access Analyzer is a service that helps identify potential resource-access risks by analyzing resource-based policies in the AWS environment. IAM Access Analyzer can also generate IAM policies based on access activity in the AWS CloudTrail logs. By using IAM Access Analyzer, the company can create an SCP that grants only the permissions that are required for the application to run, and denies all other services. This way, the company can enforce the use of only approved AWS services and reduce the risk of unauthorized access12 Create an OU for the account. Move the account into the new OU. An OU is a container for accounts within an organization that enables you to group accounts that have similar business or security requirements. By creating an OU for the account, the company can apply policies and

manage settings for the account as a group. The company should move the account into the new OU to make it subject to the policies attached to the OU3 Attach the new SCP to the new OU. Detach the default FullAWSAccess SCP from the new OU. An SCP is a type of policy that specifies the maximum permissions for an organization or organizational unit (OU). By attaching the new SCP to the new OU, the company can restrict the services that are available to all accounts in that OU, including the account that runs the application. The company should also detach the default FullAWSAccess SCP from the new OU, because this policy allows all actions on all AWS services and might override or conflict with the new SCP45 The other options are not correct because they do not meet the requirements or follow best practices. Creating an SCP that denies the services that IAM Access Analyzer identifies is not a good option because it might not cover all possible services that are not approved or required for the application. A deny policy is also more difficult to maintain and update than an allow policy. Creating an SCP that allows the services that IAM Access Analyzer identifies and attaching it to the organization's root is not a good option because it might affect other accounts and OUs in the organization that have different service requirements or approvals.
Creating an SCP that allows the services that IAM Access Analyzer identifies and attaching it to the management account is not a valid option because SCPs cannot be attached directly to accounts, only to OUs or roots.
1: Using AWS Identity and Access Management Access Analyzer - AWS Identity and Access Management
2: Generate a policy based on access activity - AWS Identity and Access Management
3: Organizing your accounts into OUs - AWS Organizations
4: Service control policies - AWS Organizations
5: How SCPs work - AWS Organizations
涉及服務：CloudTrail、Organizations/Control Tower、IAM/SCP

第 7 題（No.266） 正確答案：B

（此題題庫未附解析）
涉及服務：CloudFormation、Config、Organizations/Control Tower、IAM/SCP

第 8 題（No.343） 正確答案：D

Verify No SCP Blocking Access:
Ensure that no Service Control Policy (SCP) is blocking access for developers to the S3 bucket. SCPs are applied at the organization or organizational unit (OU) level in AWS Organizations and can restrict what actions users and roles in the affected accounts can perform.
Verify No IAM Policy Permissions Boundaries Blocking Access:
IAM permissions boundaries can limit the maximum permissions that a user or role can have. Verify that these boundaries are not restricting access to the S3 bucket.
Make Necessary Changes to SCP and IAM Policy Permissions Boundaries:
Adjust the SCPs and IAM permissions boundaries if they are found to be the cause of the access issue. Make sure these changes are reflected in the code maintained in the AWS CodeCommit repository.
Invoke Deployment Through CloudFormation:
Commit the updated policies to the CodeCommit repository.
Use AWS CloudFormation to deploy the changes across the relevant accounts and resources to ensure that the updated permissions are applied consistently.
By ensuring no SCPs or IAM policy permissions boundaries are blocking access and making necessary changes if they are, the DevOps engineer can resolve the access issue for developers trying to access the S3 bucket.
References:
AWS SCPs
IAM Permissions Boundaries
Deploying CloudFormation Templates

涉及服務：CodeCommit、CloudFormation、Config、Organizations/Control Tower、IAM/SCP、S3

第 9 題（No.355） 正確答案：B、C、E

Mounting EFS to EC2-backed EKS nodes requires:
* NFS (port 2049) open from nodes to EFS (Security Group rule).
* Mount targets in each subnet/AZ where nodes reside.
* IAM role for the EFS CSI driver with elasticfilesystem:ClientMount and ClientRootAccess permissions. These are the standard setup requirements in "Using the Amazon EFS CSI Driver with Amazon EKS."

涉及服務：EC2/Auto Scaling、EKS、IAM/SCP

第 10 題（No.409） 正確答案：B

Accessing a secret from AWS Secrets Manager that is encrypted with a customer managed KMS key requires two distinct permission layers to succeed:
* Secrets Manager permissions (via IAM) such as secretsmanager:GetSecretValue for the IAM role assumed by the Kubernetes service account.
* KMS key usage permissions in the KMS key policy , allowing the same IAM principal to perform kms:Decrypt (and possibly kms:GenerateDataKey) on the customer managed key.

In this scenario, the service account assumes an IAM role explicitly created to access the secrets. The symptom is an HTTP 403 "Access Denied" when retrieving the secret. If the IAM role has Secrets Manager permissions but the call still fails, the typical root cause is that the KMS key policy does not trust or allow that IAM role , so the decrypt operation fails.
Option B correctly identifies that the KMS key policy must include the Kubernetes service account IAM role as a principal with the appropriate KMS actions.
Option A and C refer to the EKS cluster IAM role, which is not the principal making the call. Option D is unrelated: the role's ability to "access the EKS cluster" does not affect its ability to call Secrets Manager or KMS. The missing KMS key policy permission is the underlying cause.

涉及服務：EKS、IAM/SCP、KMS、Secrets Manager